BLUE FAIRY DEVELOPMENT

# BlueFairy Anti-Spam

Invisible spam protection for WordPress and WooCommerce. No CAPTCHAs, no friction.

Version 1.2.3 · GPL-2.0-or-later · WordPress 6.5+ · PHP 8.1+
bluefairydevelopment.com

# BlueFairy Anti-Spam — Feature Guide

Invisible spam protection for WordPress and WooCommerce. No CAPTCHAs, no puzzles, no friction for real visitors.

## Requirements and Installation

| Requirement | Minimum |
|---|---|
| WordPress | 6.5 |
| PHP | 8.1 |
| WooCommerce | Optional |

1. Install from **Plugins > Add New** (search for "BlueFairy Anti-Spam"), or upload the `bluefairy-antispam` folder to `wp-content/plugins/`.
2. Activate it under **Plugins > Installed Plugins**.
3. That's all. The honeypot and the time trap protect every supported form straight away.

Optional settings are under **Tools > Anti-Spam**.

## Forms Protected

- WordPress comments, from the comment form and from the comments REST API
- WordPress user registration
- WooCommerce product reviews
- WooCommerce My Account registration
- WooCommerce shortcode checkout
- WooCommerce Block checkout (Stop Forum Spam check only; see below)
- BlueFairy Recipes Pro recipe reviews

Logged-in users skip every check, so real customers never meet any of them.

## Honeypot Trap

A hidden field is added to every protected form. Real visitors never see it: it sits 9,999 pixels off-screen and is marked `aria-hidden`. Only bots that fill in every field they find trip it.

The field name is picked from a pool of eight realistic-sounding names (such as `website2`), a different one per form type, so a bot cannot learn one name and skip it.

## Time Trap

When the page loads, a signed token goes into a hidden field. It holds a nonce, the time and the form type, signed with HMAC-SHA256 and a secret key only your site knows. The key is made at activation, made again automatically if it is ever lost (after a database restore, for example), and is not autoloaded. If the key cannot be stored at all, the time trap refuses every logged-out submission rather than accept tokens anyone could sign.

On submit, the plugin checks the signature and how long the visitor took. A form sent in under 3 seconds (the default; you can set 1 to 120) is refused, because bots submit instantly and people take a few seconds. Tokens expire after 24 hours. The form type is part of the signature, so a token from the comment form cannot be reused on the checkout.

Each form token is single-use. The first submission with a token is checked as usual; a second submission with the same token is a replay. A replayed comment or review is accepted but **held for moderation**, never published straight away and never refused, and the Spam Log records it with the trap `replay`. On registration and checkout, which cannot be held, a replay is logged and let through. A real visitor rarely sends a token twice: pressing Back and resending after WordPress refused a comment is the usual case, and that comment waits for you in moderation instead of being lost.

The time trap works on cached pages. A page served from a full-page cache carries the token made when the cache was filled, so every visitor of that copy would share it. A small script therefore swaps the token for a fresh one once, as the page loads (a `GET` to `/wp-json/bfas/v1/token`, never cached), and the 3 seconds count from then. Nothing the visitor does afterwards fetches a token again, so autofill and fast typists are timed from the page load as before.

Without JavaScript the page's own token stays and works as before: the first comment with it passes, and later comments from other visitors of the same cached copy are held for moderation. A cached token expires 24 hours after the cache was filled; with JavaScript, visitors get a fresh one regardless.

## Visitor IP Behind Cloudflare

Behind Cloudflare, every request reaches your server from one of Cloudflare's machines. Unless the server is set to restore the visitor's own address, WordPress sees Cloudflare's address for every visitor, and so would the Stop Forum Spam check and the block log.

With **Auto-detect Cloudflare** on (the default), the plugin uses the visitor address Cloudflare passes on in its `CF-Connecting-IP` header, but only when the request really comes from Cloudflare's published address ranges. A visitor who sends that header directly is ignored, so it cannot be used to fake an address. The ranges are built into the plugin; it never downloads them.

**Tools > Site Health** shows whether requests arrive through Cloudflare without the visitor's address being restored. The best fix is on the server (Apache `mod_remoteip`, nginx `real_ip`, or LiteSpeed's "Use Client IP in Header"), because that corrects the address for all of WordPress, not just this plugin. Your host can turn it on.

Site Health also warns when requests arrive from a local or private address, such as `127.0.0.1`. That is normal on a development site. On a live site it usually means a tunnel or proxy on the same network

(Cloudflare Tunnel, for example), and then every visitor appears to come from that one address. Restore the visitor's address on the server, or use the `bluefairy_antispam_client_ip` filter.

Some servers report IPv4 visitors in IPv6 form (`::ffff:203.0.113.9`). The plugin treats such an address as the IPv4 address it stands for.

---

## Stop Forum Spam (optional)

Stop Forum Spam keeps a shared database of known spammer IP addresses and e-mail addresses.

**Off by default.** Turning it on sends the visitor's IP address and e-mail address to `api.stopforumspam.org`. Only turn it on if your privacy policy says so.

- An answer is cached for 7 days for a listed visitor and 1 hour for a clean one.
- After 5 failed lookups in a row the check is skipped for 10 minutes, so an outage never blocks your forms.
- The confidence threshold (default 1, range 0 to 100) decides how sure Stop Forum Spam must be before a visitor is refused. 0 refuses any match.
- With a free Stop Forum Spam API key, visitors refused because Stop Forum Spam lists them, and comments you mark as spam, are reported back to them. Honeypot and time-trap blocks are not reported. A report sends the visitor's IP address, email address and the part of the email before the @ as the username; a submission without an email address is not reported.

---

## Comments Through the REST API

WordPress can accept comments through its REST API (`/wp/v2/comments`). Logged-out visitors can only do that when a site turns it on with the `rest_allow_anonymous_comments` filter; it is off by default.

Those comments do not come from a form, so they usually carry no time-trap token. The plugin still refuses them outright when:

- the request fills in the honeypot field,
- the request sends a time-trap token that is forged, too fast or expired, or
- Stop Forum Spam lists the visitor (when that check is on).

A comment that passes these checks but has no token is **held for moderation**, never published straight away. WordPress's own checks (flood, duplicates, disallowed words, moderation words and the links limit) still apply as usual. A refused comment gets a JSON error with status 403.

A script that renders the form fields with the `bluefairy_antispam_render_fields` action and sends them with the comment is checked exactly like the comment form.

---

# WooCommerce

## Shortcode checkout

Full protection: the honeypot and the time trap are added with the `woocommerce_after_order_notes` hook and checked on `woocommerce_checkout_process`.

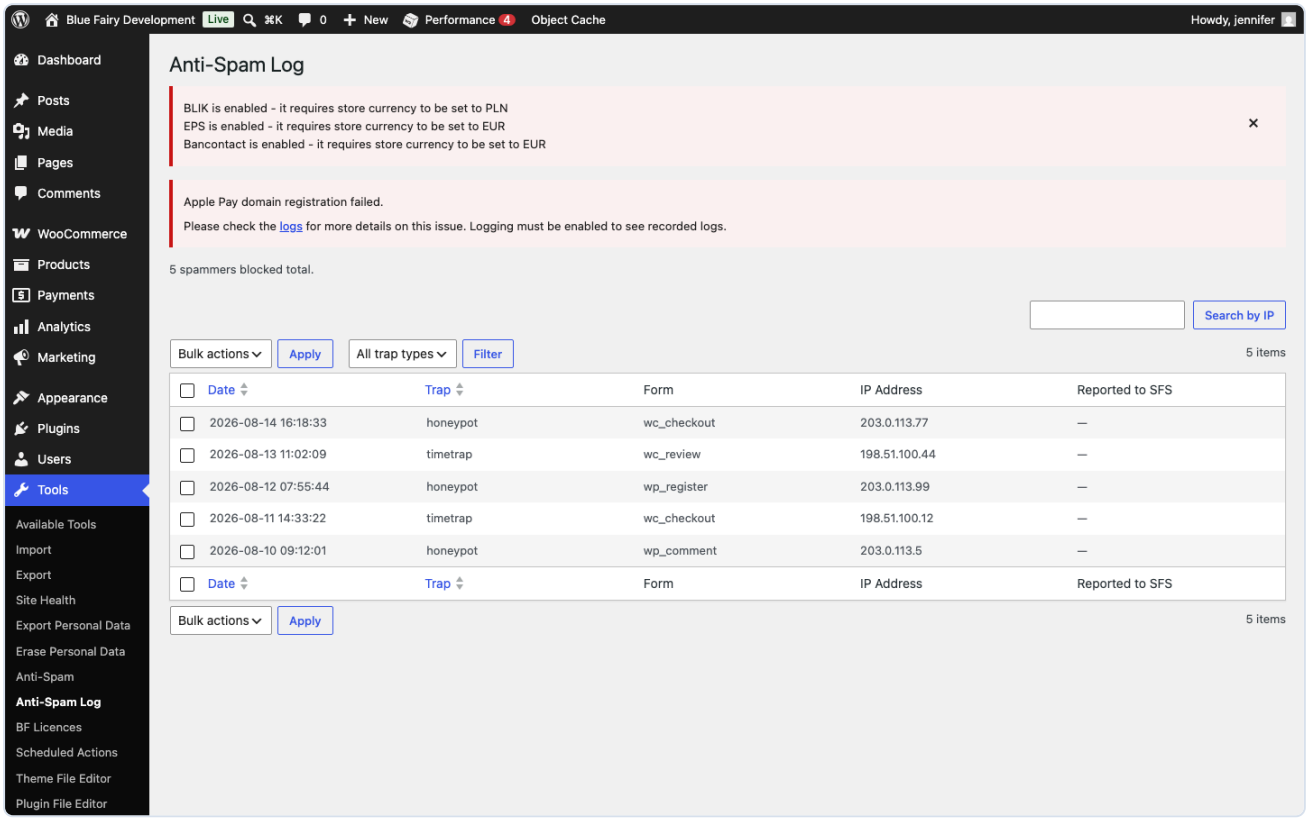
## Block checkout

The Block checkout sends the order through the WooCommerce Store API as JSON, not as a form, so the honeypot and time-trap fields cannot be added to it. Only the Stop Forum Spam check applies there, when it is on. This is a limit of the Block checkout, not a fault in the plugin.

# BlueFairy Recipes Pro Reviews

The recipe review form posts to its own REST route, which saves the review as a comment. The honeypot and time trap are added to that form through its `bfrcp_review_form_fields` action and checked as the `recipe_review` form. A blocked review gets an error message in the form instead of an error page.

# What Gets Logged



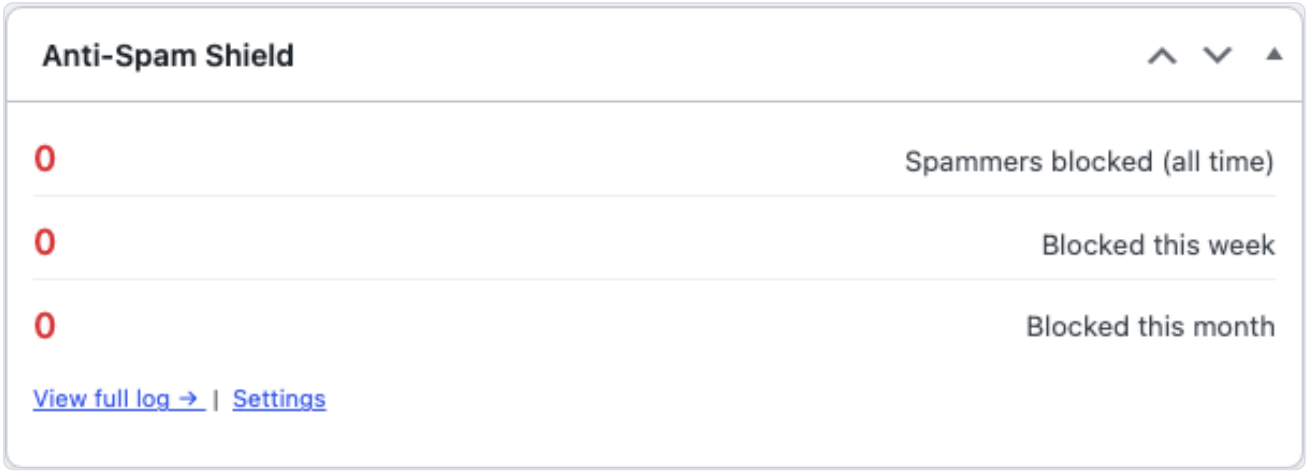

The Anti-Spam Log: search, filter by trap, and the Reported to SFS view

Every refused submission is written to the log, at **Tools > Anti-Spam Log**.

| Field | Value |
|---|---|
| Date | UTC time of the block |
| Trap | `honeypot`, `timetrap` or `sfs` |
| Form | `wp_comment`, `wp_comment_rest`, `wp_register`, `wc_review`, `recipe_review`, `wc_register`, `wc_checkout`, `wc_checkout_block` |
| IP | The visitor's IP address |
| Email hash | HMAC-SHA256 of the e-mail address; the address itself is never stored |
| Reported to SFS | Whether the block was reported to Stop Forum Spam |

The log page can search by IP address, filter by trap, sort by date or trap, show only the entries reported to Stop Forum Spam, and delete in bulk. Entries are deleted after 90 days (you can set 1 to 3,650), up to 1,000 a day.

## Dashboard Widget




The Anti-Spam Shield widget on the WordPress Dashboard

The **Anti-Spam Shield** widget on the WordPress Dashboard shows:

- spammers blocked, all time
- blocked this week and this month
- a breakdown by trap

## Settings Reference

All settings are under **Tools > Anti-Spam**.

| Setting | Default | What it does |
|---|---|---|
| Honeypot | On | Turns the honeypot on or off everywhere |
| Time trap | On | Turns the time trap on or off everywhere |
| Minimum submit time | 3 seconds | Faster submissions are refused (1 to 120) |
| Auto-detect Cloudflare | On | Behind Cloudflare, use the visitor address Cloudflare passes on, believed only from Cloudflare's own addresses |
| Stop Forum Spam lookup | Off | Checks visitors against Stop Forum Spam |
| Stop Forum Spam API key | Empty | Needed only to report spammers back |
| Confidence threshold | 1 | Refuse when Stop Forum Spam's confidence is at or above this (0 to 100) |
| Log retention | 90 days | How long log entries are kept (1 to 3,650) |

## For Developers

Other plugins can protect their own forms with two hooks:

- **Action** `bluefairy_antispam_render_fields( string $form_type )` prints the honeypot and time-trap fields for a form type inside your form.
- **Filter** `bluefairy_antispam_check( bool $is_spam, array $post_data, string $form_type, string $ip, string $email )` runs the honeypot and time-trap checks on the submitted data and returns `true` for spam. A refusal is logged.

Use your own form type name, the same one in both calls.

- **Filter** `bluefairy_antispam_client_ip( string $ip, string $remote_addr )` returns the visitor address the plugin uses. Behind a proxy other than Cloudflare, return the visitor's address from your proxy's header, but only after checking the request came from your proxy. A value that is not a valid IP address is ignored, and the address the plugin worked out itself is used instead.

## Frequently Asked Questions

### Will this break my checkout?

No. Real customers never touch a trap field. The honeypot is invisible, and the time-trap token lasts 24 hours, far longer than any checkout takes.

### Do I need a Stop Forum Spam account?

No. Stop Forum Spam is optional and off by default. The honeypot and the time trap work without it. An API key is needed only to report spammers back.

### What gets stored?

For a refused submission: the time, the trap, the form, the IP address and a hash of the e-mail address. The e-mail address itself is never stored.

### Does it work alongside other security plugins?

Yes. It uses the standard WordPress and WooCommerce hooks and changes nothing global.

---

## Licence and Support

GPL-2.0-or-later. Always free.

- Support: bluefairydevelopment.com
- Bug reports and contributions: github.com/bluefairydevelopment/bluefairy-antispam
- Security reports: see SECURITY.md in the repository